S7 PROJECT MID REVIEW

AMRITA VISHWA VIDYAPEETHAM
DEEMED TO BE UNIVERSITY

QUANTUM SECURE - ZERO TRUST ARCHITECTURE

Guide Name:
Shri Hari N. N., Assistant Professor

Student Name:
Ajay Koppaka : AM.SC.U4CYS23006
Abhinav Pasunuri : AM.SC.U4CYS23033

Outline

1. Introduction
2. Problem Definition
3. Literature Review Summary
4. Research Gap
5. Methodology
6. Design/ Architecture
7. Algorithms (if any)
8. Result Analysis.
9. Project Time Line (Plan)
10. Reference

OVERVIEW

- **Zero Trust** rely on Never Trust Always Verify
- **Passwordless FIDO Authentication** Validated against a decentralized, fault-tolerant network
- **TPM Root of Trust** Cryptographically anchored by unique hardware fingerprints
- **Stealth Connectivity** Single Packet Authorization (SPA) cloaks devices before tunneling.
- **Continuous Validation** Enforced via TPM-signed health and behavioral attestations

INTRODUCTION

- **Perimeterless** Architecture Eliminates traditional boundaries by treating every IoT device as an untrusted endpoint.
- **Identity-First Defense** Shifts access control from network location to cryptographic identity verification.
- **Proactive Surface Reduction** Prevents unauthorized discovery and lateral movement through strict default-deny policies
- **Strict Least Privilege** Restricts device communication exclusively to essential authorized workloads and services
- **Dynamic Trust Evaluation** Adapts access policies continuously based on real-time device context and telemetry

PROBLEM STATEMENT

- Easily Spoofed Identities **Lack of hardware-anchored trust** allows attackers to effortlessly clone devices and bypass basic network authentication
- Static **Credential Vulnerability** Hardcoded passwords and centralized key management create high-value targets susceptible to widespread compromise
- Exposed Attack Surfaces Devices broadcasting their presence via open listening ports invite continuous reconnaissance and automated botnet exploitation

NOVELTY

- **Decentralized Control Plane:** Eliminates the single point of failure typical in IAM systems by splitting identity keys across an automated, fault-tolerant multi-controller mesh.
- **Dual-Layer Cryptographic Binding:** Couples passwordless FIDO protocol authentication directly with uncloneable, physical TPM-anchored hardware fingerprints.
- **Pre-Authentication Network Cloaking:** Utilizes Single Packet Authorization (SPA) to keep the data plane and access gateways entirely hidden from public reconnaissance and automated scans.

LITERATURE REVIEW

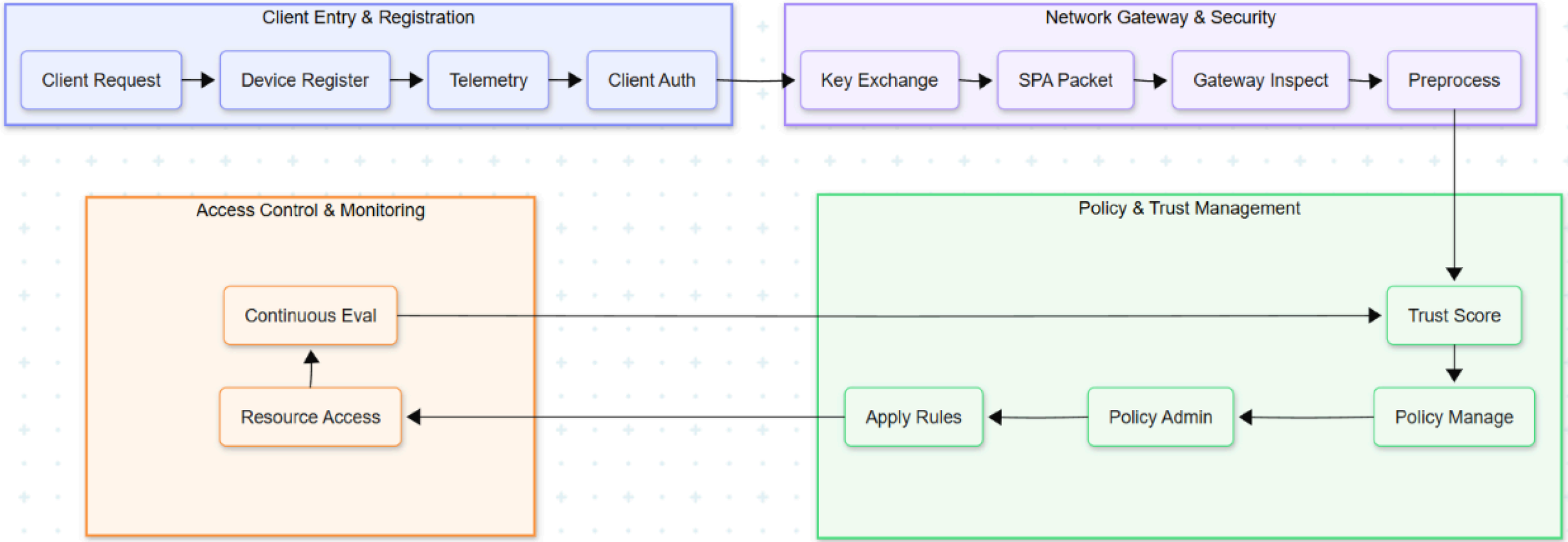
Literature Review Summary

SINO	PAPER	YEAR	Key Contribution	Demerit	Evaluation Metrics
1	Standards-Compliant Zero Trust Framework-Based Software-Defined Perimeter (SDP) for Securing Residential IoT Networks	2026	Combines MUD policies with SDP to create a "dark" smart-home network that hides devices until authenticated and blocks lateral movement	Classical crypto only (not quantum-safe); single SDP controller is a point of failure; device identity not TPM-bound	Auth latency, throughput, resource overhead, attack mitigation
2	ZTA-IoT: A Novel Architecture for Zero-Trust in IoT Systems and an Ensuing Usage Control Model	2024	ZT architecture for IoT, the ZTA-IoT-ACF score-based access control framework, and the UCON-IoT continuous usage control model	Centralized policy decision; no hardware root of trust; no post-quantum crypto; validated only as a proof-of-concept	Policy enforcement latency and performance overhead of the PoC
3	DistriTrust: Distributed and low-latency access validation in zero-trust architecture	2021	Removes the single PDP failure point: access is granted only when t-of-n distributed PDPs co-sign using threshold signatures	Threshold RSA/ECC/pairing schemes are broken by Shor's algorithm; not evaluated on constrained IoT; no device attestation	Signing and verification time, end-to-end access validation latency
4	Lightweight Cryptography for Internet of Things: A Review	2024	Surveys lightweight block ciphers and compares hardware and software implementation trade-offs for IoT	Symmetric ciphers only, with no PQC or key exchange; no experimental validation; future work limited to AES	Compares reported throughput, latency, memory/area (GE), and power/energy
5	A Study of Communication Protocols for Internet of Things (IoT) Devices: Review	2021	Compares BLE, ZigBee, Z-Wave, 6LoWPAN, LoRaWAN, NB-IoT, Wi-Fi, MQTT, and CoAP and maps them to application domains	Descriptive only; security discussed superficially; no benchmarks; no zero trust or PQC angle	Range, data rate, topology, energy consumption, QoS

RESEARCH GAP ANALYSIS

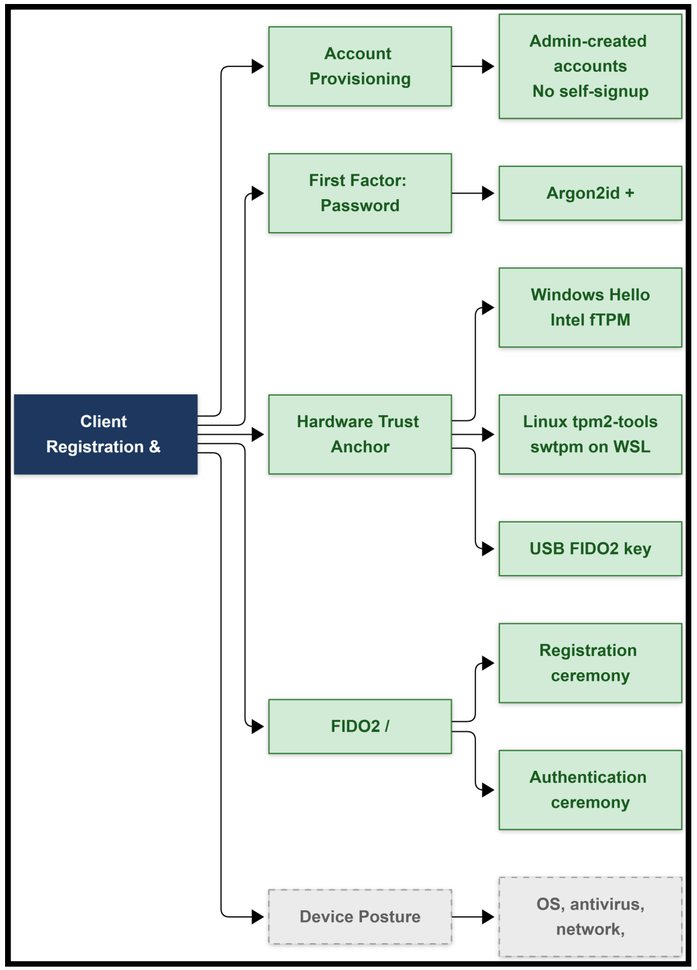
Identified Research Gaps	Gap to Solution Mapping
No Quantum Resistance: existing ZT and SDP frameworks use classical key exchange and signatures broken by Shor's algorithm.	**Quantum Vulnerability:** ML KEM key derivation for SPA provides a post-quantum secure channel.
Centralized Trust Anchor: a single controller or IdP is a single point of failure	**Centralized Trust:** Multi-controller mesh with Shamir Secret Sharing eliminates single points of failure.
Identity Not Hardware Bound: software credentials and static fingerprints can be cloned or spoofed.	**Cloneable Identity:** FIDO2 passwordless auth bound to TPM keys ensures unclonable device identity.
One Time Authentication: trust granted at entry and assumed afterwards, lacking continuous evidence.	**One Time Trust: Continuous** TPM signed attestation feeds into a Trust Score Engine for verification.
PQC on Constrained IoT: unaddressed; lightweight surveys cover only symmetric ciphers.	**Device Constraints:** Hybrid one ML KEM exchange followed by AES GCM or ChaCha20 Poly1305 results in low overhead post-handshake.

METHODOLOGY

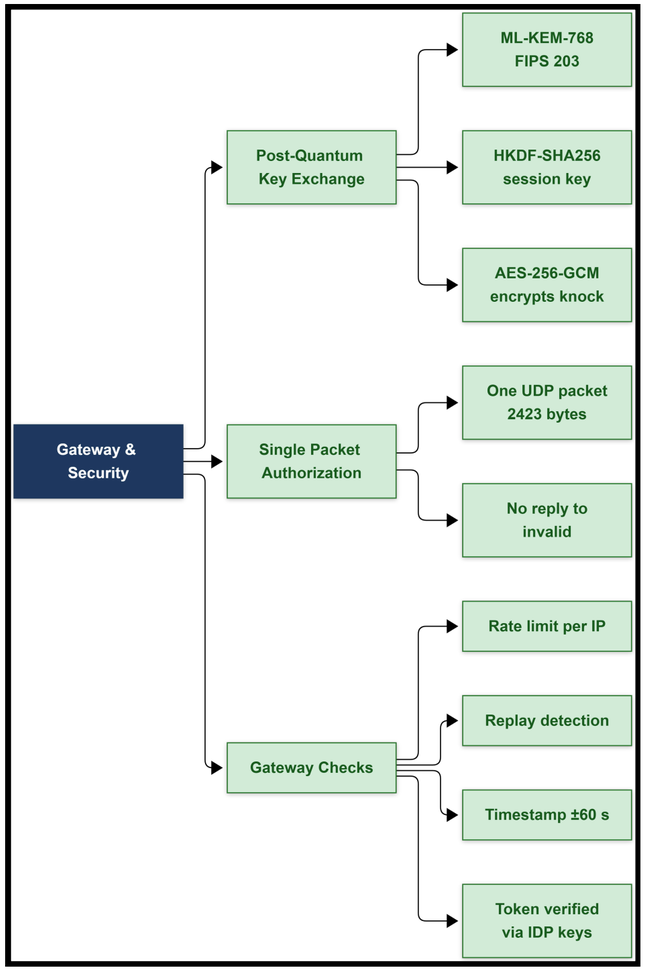


METHODOLOGY

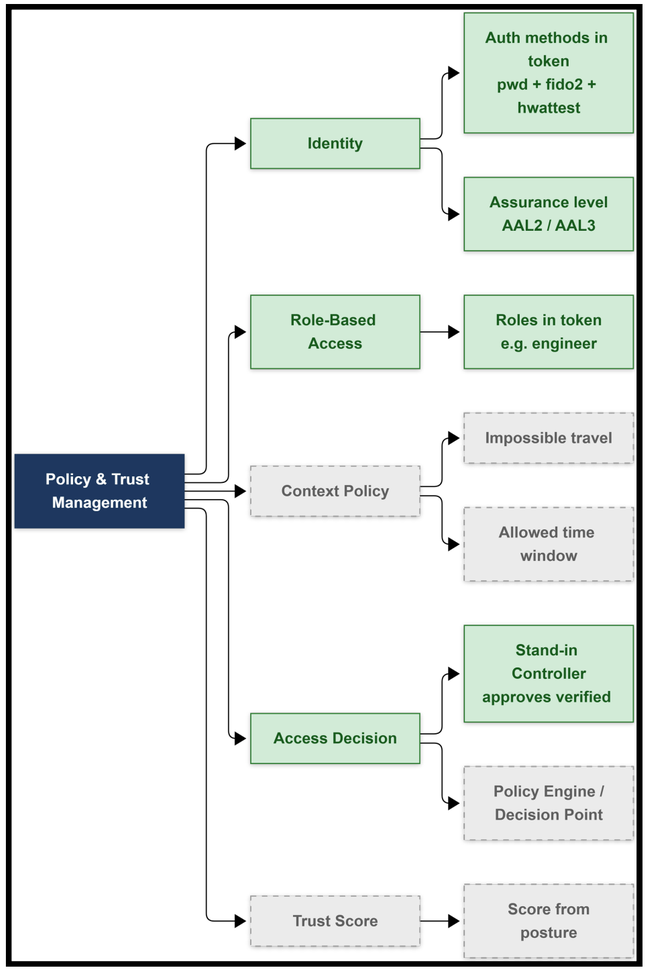
Step 1: Client Registration & Authentication



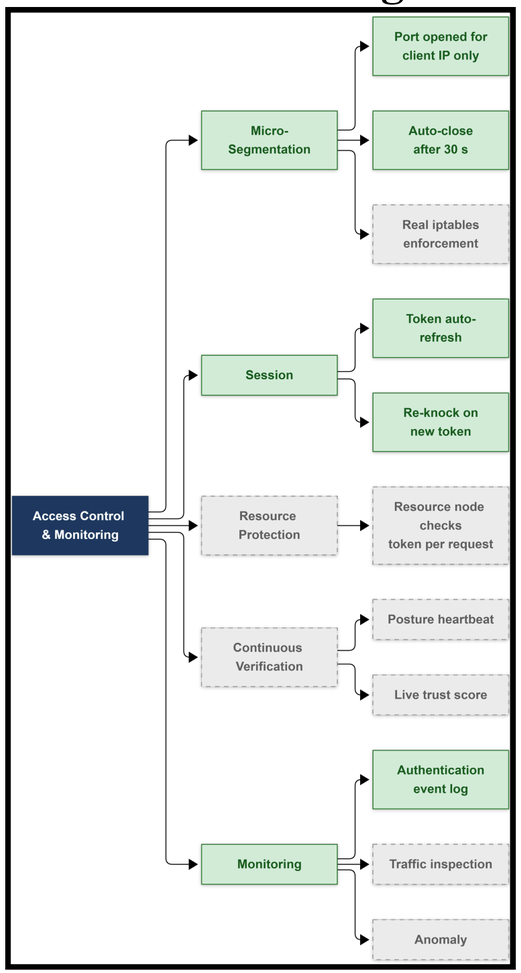
Step 2: Gateway & Security



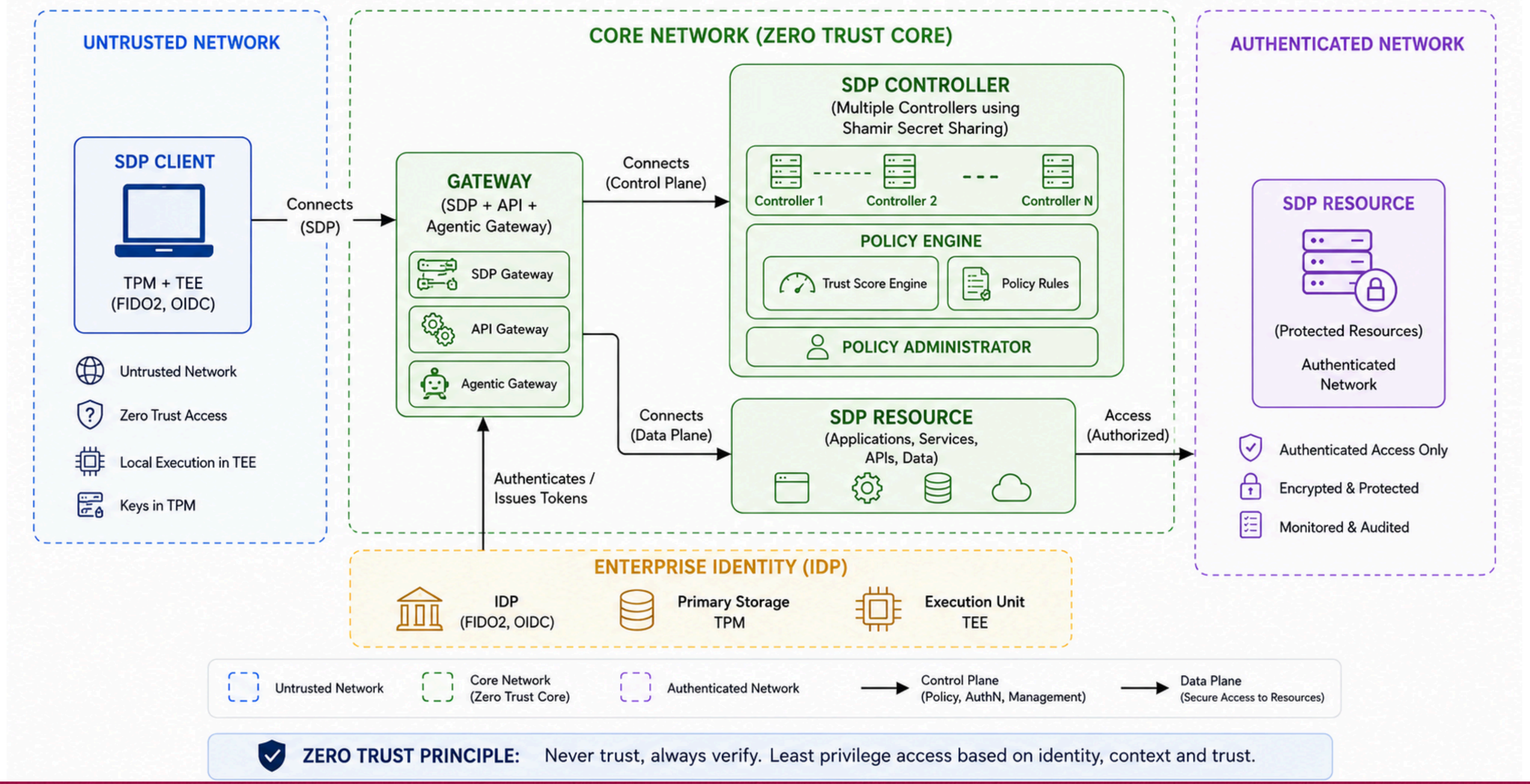
Step 3: Policy & Trust Management



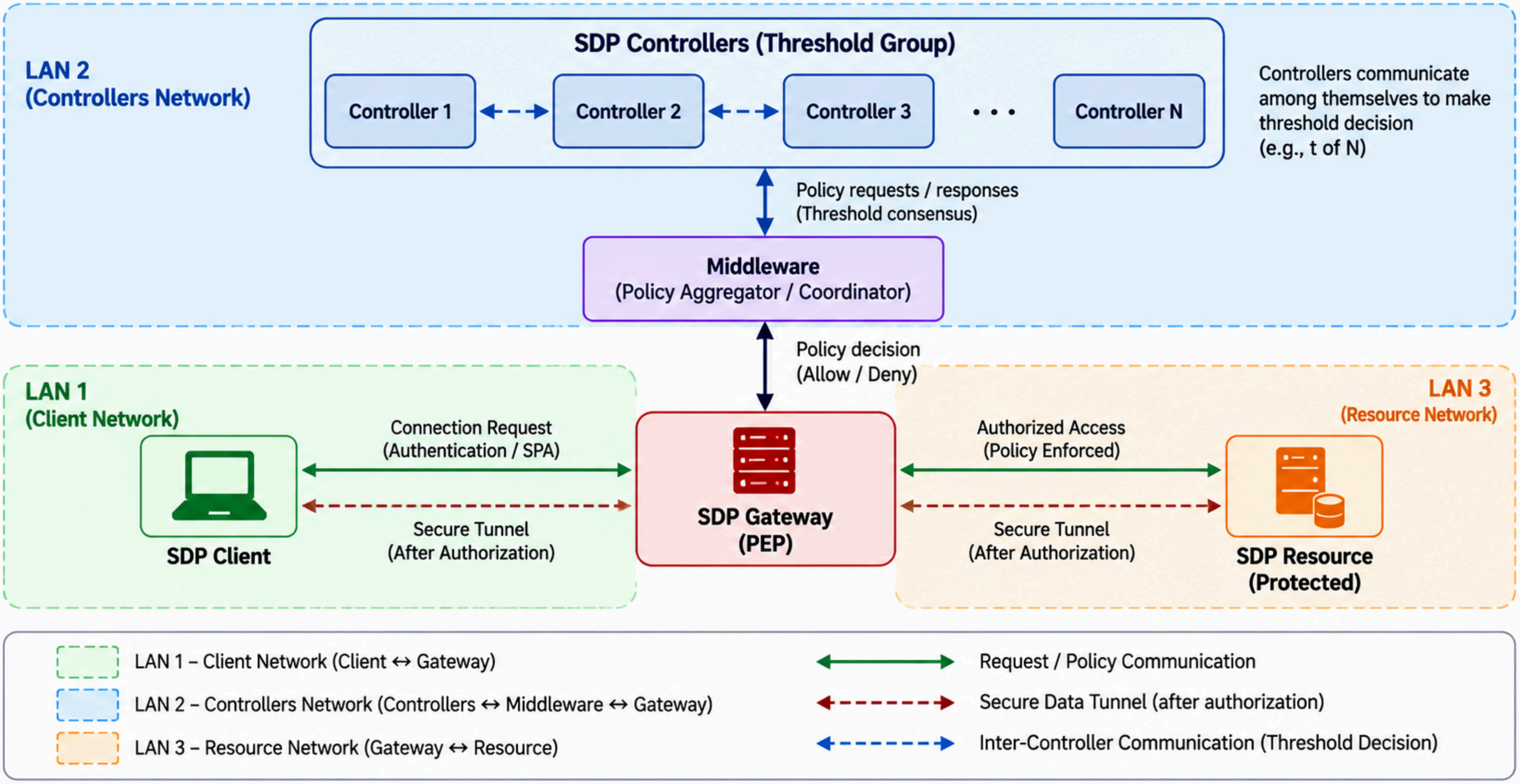
Step 4: Access Control & Monitoring



PROPOSED ARCHITECTURE



Decentralized Threshold SDP Architecture

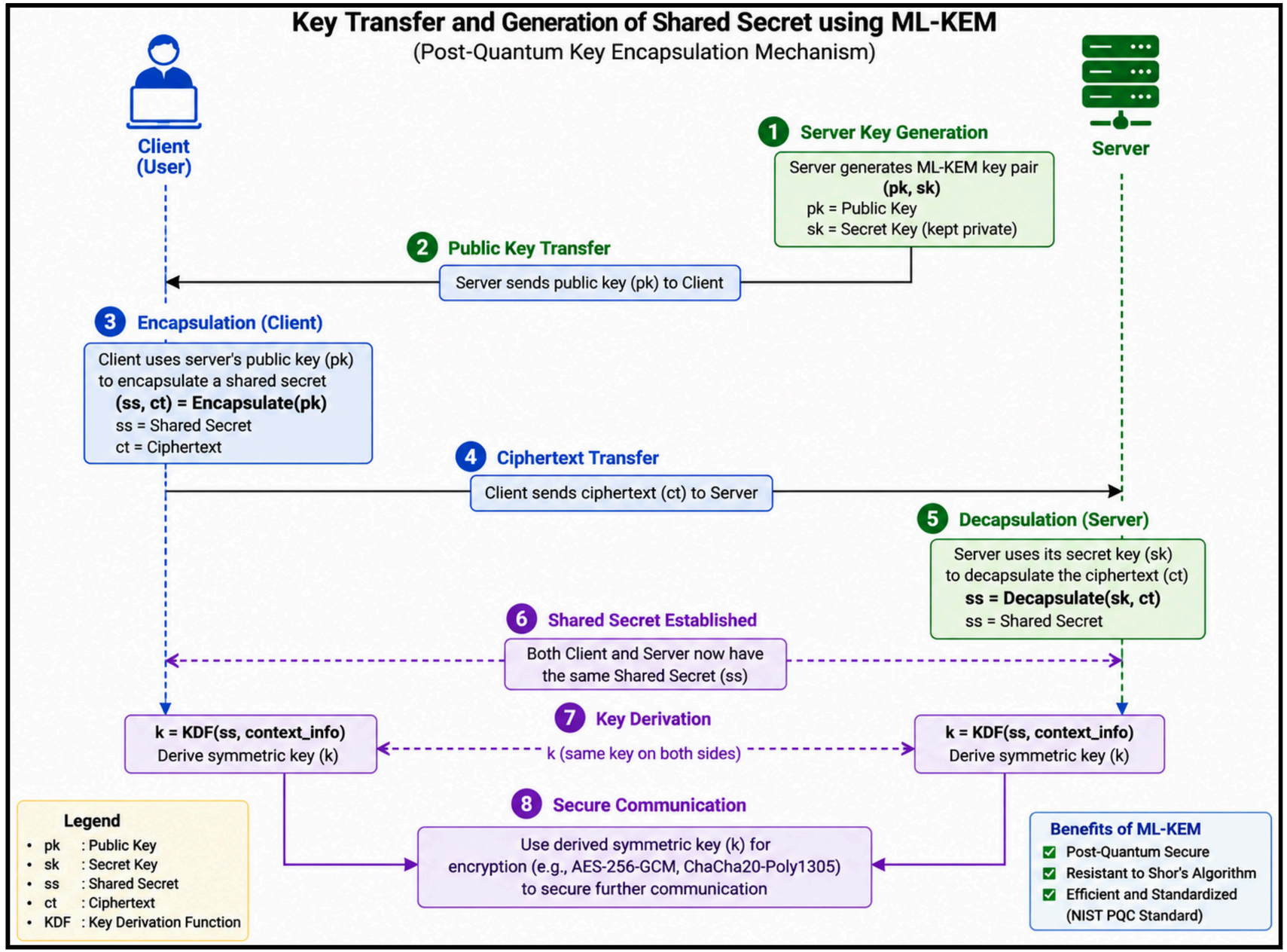


ALGORITHMS

SINO	Algorithm	Purpose	Where used	Protocol
1	ECDSA P-256 + SHA-256 (ES256)	Device key in the chip	Client (TPM / Windows Hello / USB key), IDP	WebAuthn / FIDO2, TPM 2.0
2	TPM attestation (ECDSA / RSA)	Proves the key was made in the chip	Client, IDP	WebAuthn fmt="tpm", TPM2_Certify, X.509
3	RS256 (RSA-3072)	Signs tokens	IDP, Gateway	JWT, JWKS
4	Argon2id + pepper	Password hashing	IDP	HTTP login
5	SHA-256	Hashing	Client, IDP	WebAuthn, TPM 2.0, JWKS
6	ML-KEM-768	Post-quantum key exchange	Client, Gateway	SPA knock
7	HKDF-SHA256	Makes the encryption key	Shared	SPA knock
8	AES-256-GCM	Encrypts the knock	Shared	SPA knock

SPA Security Stack

SI.NO	Symmetric Key	Asymmetric key	Asymmetric to Symmetric Key
Key Distribution	Uses the same keys for both parties	uses a sperate set of keys for encryption and decryption	Generates a shared derived key for a public-prvate key pair
Computational Overhead	Low overhead	High Overhead	Initially high overhead then low overhead after shared key derivation
The Scalability Problem	All the users share same key, cannot confirm the unique identity of a user	All users encrypt the data using a the gateway's public key and sign it with their private key, costly lookup to verify their identity at every keepalive	Users Derive unique symmetric keys based on their private keys and gateway's public key. And gateway computes the same shared key from its private key and client's public key
Algorithms	AES, Cha Cha 20, poly 1305	SLH-DSA, ML-DSA	DHKE, ML-KEM


Key Transfer and Generation of Shared Secret using ML-KEM
(Post-Quantum Key Encapsulation Mechanism)
Client (User)
Server
1 Server Key Generation
Server generates ML-KEM key pair (pk, sk)
pk = Public Key
sk = Secret Key (kept private)
2 Public Key Transfer
Server sends public key (pk) to Client
3 Encapsulation (Client)
Client uses server's public key (pk) to encapsulate a shared secret
(ss, ct) = Encapsulate(pk)
ss = Shared Secret
ct = Ciphertext
4 Ciphertext Transfer
Client sends ciphertext (ct) to Server
5 Decapsulation (Server)
Server uses its secret key (sk) to decapsulate the ciphertext (ct)
ss = Decapsulate(sk, ct)
ss = Shared Secret
6 Shared Secret Established
Both Client and Server now have the same Shared Secret (ss)
7 Key Derivation
k = KDF(ss, context_info)
Derive symmetric key (k)
k (same key on both sides)
k = KDF(ss, context_info)
Derive symmetric key (k)
8 Secure Communication
Use derived symmetric key (k) for encryption (e.g., AES-256-GCM, ChaCha20-Poly1305) to secure further communication
Legend
pk : Public Key
sk : Secret Key
ss : Shared Secret
ct : Ciphertext
KDF : Key Derivation Function
Benefits of ML-KEM
Post-Quantum Secure
Resistant to Shor's Algorithm
Efficient and Standardized (NIST PQC Standard)

ML-KEM

Result Analysis

Results at a Glance

Capability	Existing work [1][3]	Our system	Proven by
Device identity tied to hardware	❌	TPM-attested	Slides18–20
Passwordless second factor	❌	FIDO2 + Windows Hello	Slide 21
Quantum-safe access request	❌	ML-KEM-768	Slide 22
Hidden services (SPA)	✅	✅	Slide 22
Time-limited access	❌	30 s window	Slide 22

FAST IDENTITY ONLINE(FIDO2)

Core Components

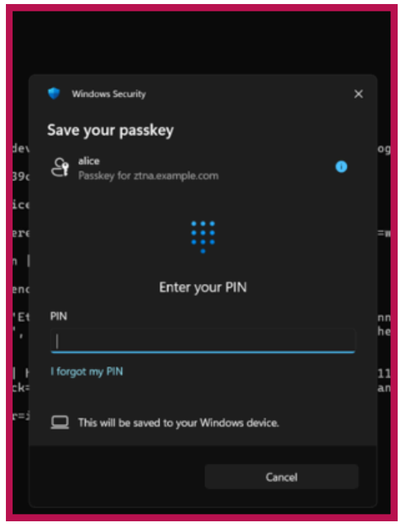
1. WebAuthn (Web Authentication API)
   - A W3C standard.
   - Provides a browser API that allows web applications to interact with FIDO authenticators.
   - Used by the Relying Party (RP) to request registration and authentication.

2. CTAP2 (Client to Authenticator Protocol)
   - Developed by the FIDO Alliance.
   - Defines communication between the client device and the authenticator.
   - Supports:
     - USB, NFC, Bluetooth, Internal platform authenticators

Main Entities

1. User
2. Browser
3. Authenticator
4. Relying Party

Device Enrolment: Key Created Inside the TPM




```
01:21:40 | FIDO2Client   | INFO     | ============================================================
01:21:40 | FIDO2Client   | INFO     | FIDO2 REGISTRATION INITIATED
01:21:40 | FIDO2Client   | INFO     | ============================================================
01:21:40 | FIDO2Client   | INFO     |     Relying Party (IDP): ztna.example.com
01:21:40 | FIDO2Client   | INFO     |     Origin: https://ztna.example.com
01:21:40 | FIDO2Client   | INFO     |     Trust anchor: internal_tpm
01:21:40 | FIDO2Client   | INFO     | Step 1/6: Requesting credential-creation options from IDP | endpoint=/fido2/register/begin
01:21:40 | FIDO2Client   | INFO     | Step 2/6: Received registration challenge from IDP | challenge_bytes=32 | flow_id=10828e5c-4611-47d9-a8a2-dad2a0ced8bf
| rp_id=ztna.example.com | pubkey_algs=[-7, -8, -35, -36, -37, -257, -47, -48, -49, -50]
01:21:40 | FIDO2Client   | INFO     | Step 3/6: Delegating to the Windows platform authenticator - confirm with Windows Hello
01:21:40 | FIDO2Client   | INFO     | Step 4/6: Windows generated the key in the TPM and attested it
01:21:40 | WinWebAuthn   | INFO     | Requesting a credential from Windows Hello - confirm on the prompt | rp_id=ztna.example.com | user=alice | options_vers
ion=4
01:22:19 | WinWebAuthn   | INFO     | Windows Hello produced a credential | fmt=tpm | credential_id=f36f1b7eb40fb4e7 | attestation_object_bytes=4002
01:22:19 | FIDO2-WinHello | INFO     | Windows Hello registration response built | fmt=tpm | credential_id=f36f1b7eb40fb4e7
01:22:19 | FIDO2Client   | INFO     | Step 5/6: Submitting attestation object to IDP | endpoint=/fido2/register/complete | credential_id=f36f1b7eb40fb4e7
01:22:19 | FIDO2Client   | INFO     | Step 6/6: IDP verified the attestation and stored the credential
01:22:19 | FIDO2Client   | INFO     | ============================================================
01:22:19 | FIDO2Client   | INFO     | FIDO2 REGISTRATION COMPLETE
01:22:19 | FIDO2Client   | INFO     | ============================================================
01:22:19 | FIDO2Client   | INFO     |     Credential ID: f36f1b7eb40fb4e741488eb95a6a68b2ccfec430b0f814b7eeb232a82e80b5aa
01:22:19 | FIDO2Client   | INFO     |     Attestation format: tpm
01:22:19 | FIDO2Client   | INFO     |     Hardware-attested: True
01:22:19 | CredCache     | INFO     | Device credential enrolled and cached | path=certs\credentials\2b6800c97f0e00af.json | backend=windows-webauthn
01:22:19 | WireGuard     | INFO     | WireGuard key pair loaded | public_key_head=96db5a7240453784
```

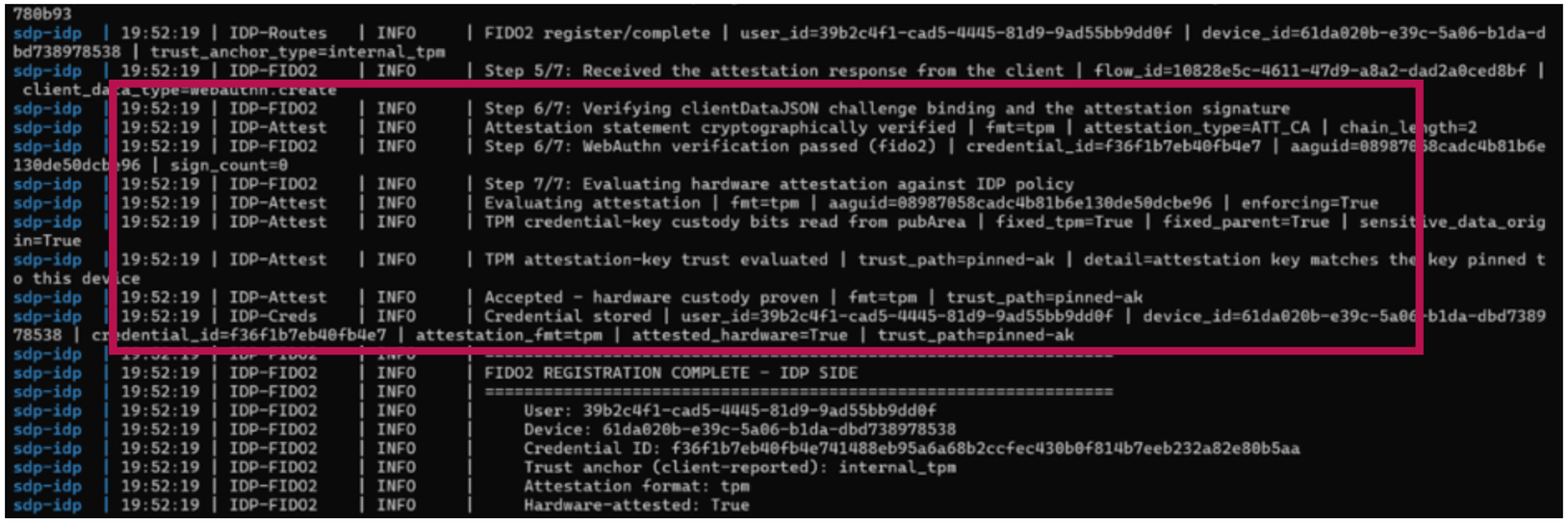
Item	Value
Authenticator	Windows Hello (Intel fTPM)
User check	Windows Hello PIN
Proof format	tpm (4002 bytes)
Result	Enrolled ✅

Windows Hello produced a credential
attestation_object_bytes=4002

Hardware-attested: True
Attestation_format=tpm

Description: The private key is created inside the TPM and can never leave it. Windows sends a signed proof of this to the IDP.

IDP Verifies the Hardware Proof



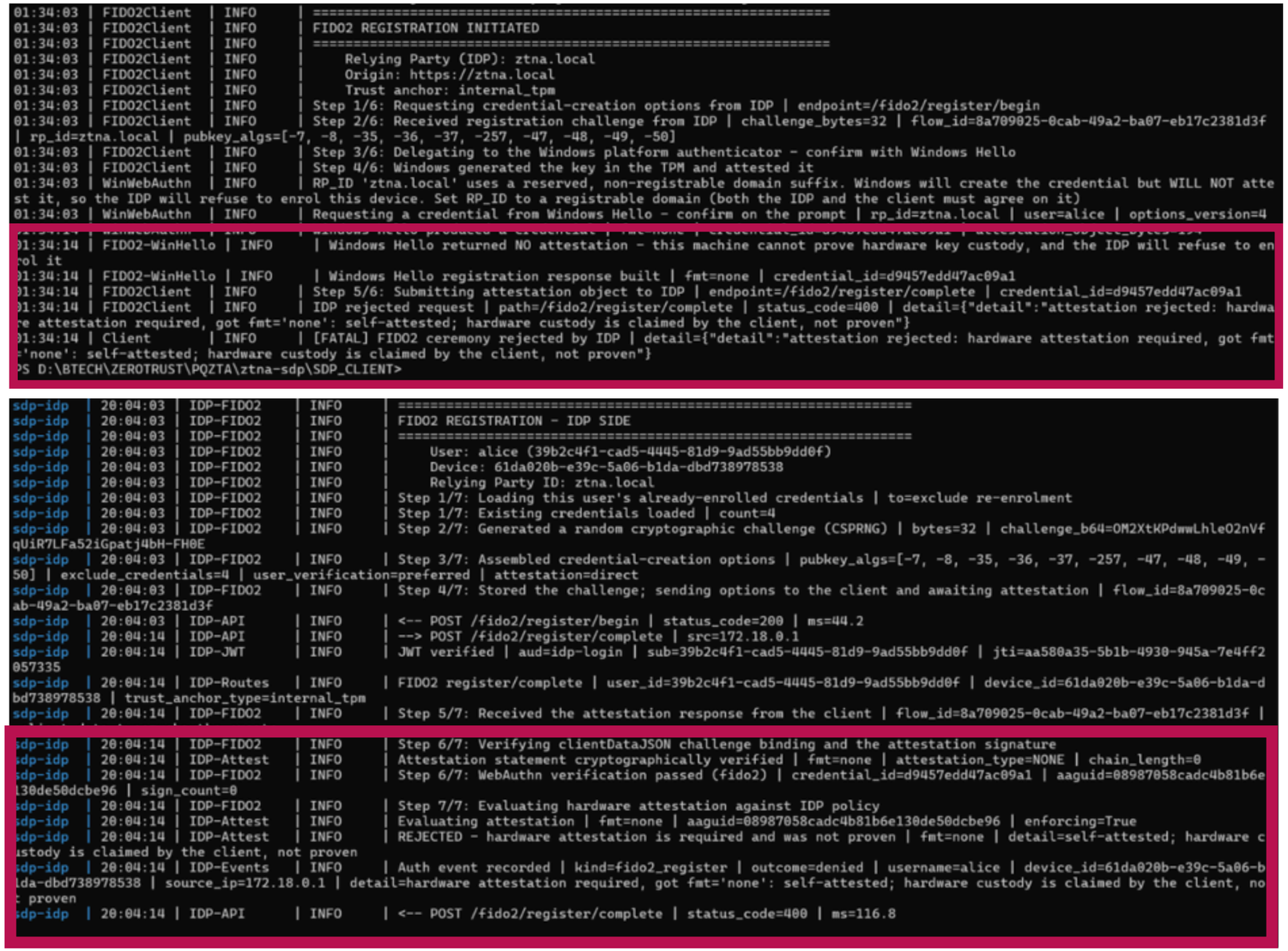
Description: The IDP does not trust what the client says it is. It checks the TPM's own signed statement before enrolling the device.

Check made by the IDP	Logged at (UTC)
Proof signature valid (certificate chain of 2)	19:52:19
Key cannot leave the TPM (fixed_tpm=True)	19:52:19
Key created inside the TPM (sensitive_data_origin=True)	19:52:19
Attestation key matches this device (pinned-ak)	19:52:19

Step 6/7: Verifying clientDataJSON

Accepted - hardware custody proven

No Hardware Proof, No Access (the comparison slide)



	Registrable domain (ztna.example.com)	(.local) domain
Proof format	tpm	none
Proof size	4002 B	194 B
IDP decision	Enrolled	Refused (HTTP 400)

Description: Same laptop, same TPM, and only the domain changed. Without hardware proof, the IDP refuses the enrolment (fail-closed).

Passwordless Login: Session Established

```
01:40:44 | FIDO2Client   | INFO     | ============================================================
01:40:44 | FIDO2Client   | INFO     | FIDO2 AUTHENTICATION SUCCESSFUL - SESSION ESTABLISHED
01:40:44 | FIDO2Client   | INFO     | ============================================================
01:40:44 | FIDO2Client   | INFO     |     Subject (user_id): 39b2c4f1-cad5-4445-81d9-9ad55bb9dd0f
01:40:44 | FIDO2Client   | INFO     |     Access token (head): eyJhbGciOiJSUzI1NiIsImtpZCI6ImQ4MTUyNmFi…
01:40:44 | FIDO2Client   | INFO     |     Access token TTL: 900s
01:40:44 | FIDO2Client   | INFO     |     Refresh token TTL: 43200s
01:40:44 | FIDO2Client   | INFO     |     Token audience: ['sdp-gateway', 'resource-node']
01:40:44 | FIDO2Client   | INFO     |     AMR (auth methods): ['pwd', 'fido2', 'hwattest']
01:40:44 | FIDO2Client   | INFO     |     Roles: ['engineer']
01:40:44 | FIDO2Client   | INFO     |     Knock ticket: 133 bytes, valid 60s, single use
01:40:44 | FIDO2Client   | INFO     |     Hardware-attested: True
01:40:44 | FIDO2Client   | INFO     |     Gateways listed: ['gw-1']
01:40:44 | Client        | INFO     | [4/5] IDP session established | hardware_attested=True | access_ttl_s=900
01:40:44 | Client        | INFO     | [5/5] SPA knock to Gateway... | gateway=172.24.13.198:62201 | port=443 | protocol=tcp
01:40:44 | SPA-Client    | INFO     | ML-KEM encapsulated against Gateway public key | ct_len=1088
01:40:44 | TEE           | INFO     | [TEE] Secure scope entered: ml-kem-shared-secret | mlock_available=False
01:40:44 | TEE           | INFO     | [TEE] Secure scope exited, 1 secret(s) zeroized: ml-kem-shared-secret
01:40:44 | SPA-Client    | INFO     | SPA packet built | total_bytes=2423
01:40:44 | SPA-Client    | INFO     | SPA knock sent | gateway=172.24.13.198:62201 | bytes=2423
01:40:44 | SPA-Client    | INFO     | SPA knock result | accepted=True | reply=SPA_OK
01:40:44 | Client        | INFO     | [5/5] Gateway accepted the SPA knock
01:40:44 | TokenRefresh  | INFO     | Refresh loop started | interval_s=840
01:40:44 | Client        | INFO     | SESSION LIVE - access token will auto-refresh. Ctrl-C to exit.
```

Token	Size / lifetime	Purpose
Access token	15 min	Shown to the Gateway
Refresh token	12 h	Renews the session
Knock ticket	133 B, 60 s, single use	Inside the SPA knock

AMR: Authentication Methods References
pwd: Password
fido2: Fast IDentity Online 2
hwattest: Hardware Attestation
SPA: Single Packet Authorisation

Description: The token records all three proofs: password, FIDO2, and a hardware-attested device.

Quantum-Safe SPA Knock

```
01:40:44 | FIDO2Client | INFO |     Token audience: ['sdp-gateway', 'resource-node']
01:40:44 | FIDO2Client | INFO |     AMR (auth methods): ['pwd', 'fido2', 'hwattest']
01:40:44 | FIDO2Client | INFO |     Roles: ['engineer']
01:40:44 | FIDO2Client | INFO |     Knock ticket: 133 bytes, valid 60s, single use
01:40:44 | FIDO2Client | INFO |     Hardware-attested: True
01:40:44 | FIDO2Client | INFO |     Gateways listed: ['gw-1']
01:40:44 | Client      | INFO | [4/5] IDP session established | hardware_attested=True | access_ttl_s=900
01:40:44 | Client      | INFO | [5/5] SPA knock to Gateway... | gateway=172.24.13.198:62201 | port=443 | protocol=tcp
01:40:44 | SPA-Client  | INFO | ML-KEM encapsulated against Gateway public key | ct_len=1088
01:40:44 | TEE         | INFO | [TEE] Secure scope entered: ml-kem-shared-secret | mlock_available=False
01:40:44 | TEE         | INFO | [TEE] Secure scope exited, 1 secret(s) zeroized: ml-kem-shared-secret
01:40:44 | SPA-Client  | INFO | SPA packet built | total_bytes=2423
01:40:44 | SPA-Client  | INFO | SPA knock sent | gateway=172.24.13.198:62201 | bytes=2423
01:40:44 | SPA-Client  | INFO | SPA knock result | accepted=True | reply=SPA_OK
01:40:44 | Client      | INFO | [5/5] Gateway accepted the SPA knock
01:40:44 | TokenRefresh| INFO | Refresh loop started | interval_s=840
01:40:44 | Client      | INFO | SESSION LIVE - access token will auto-refresh. Ctrl-C to exit.
```

Description: Only a knock carrying a valid token opens the port, only for that client, and only for 30 seconds.

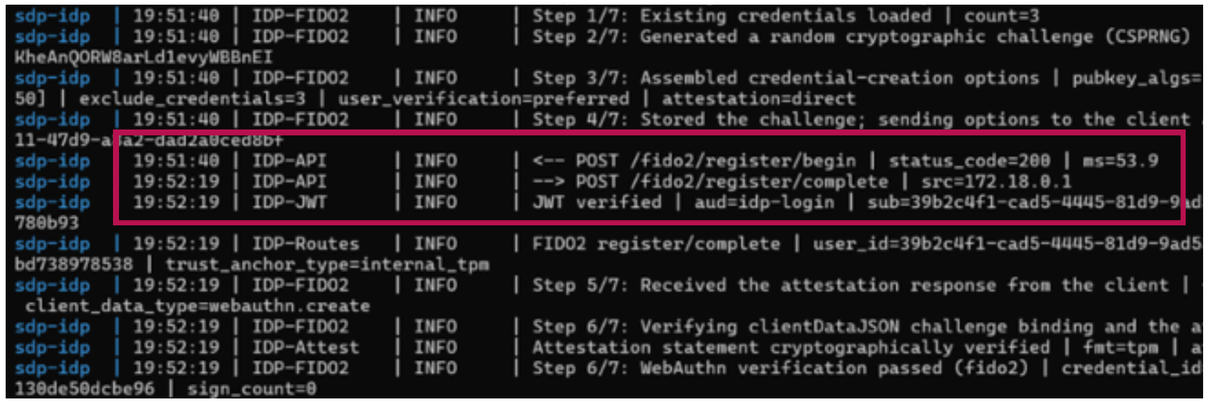
Step	Where	Time
ML-KEM-768 knock sent (2423 B)	Client	01:40:44
Token verified, approved	Gateway	01:40:44
Port 443 opened for this IP	Gateway	01:40:44
Port closed automatically	Gateway	01:41:14 (30 s)

```
(h3xn1nj4㉿4bh7n4v)-[/mnt/d/BTECH/ZEROTRUST/PQZTA/ztna-sdp/SDP_GATEWAY]
$ .venv/bin/python main.py
01:20:00 | Gateway      | INFO     | ============================================================
01:20:00 | Gateway      | INFO     | SDP GATEWAY STARTING
01:20:00 | Gateway      | INFO     | IDP link: https://localhost:9443 (mTLS)
01:20:00 | Gateway      | INFO     | ============================================================
01:20:00 | GatewayKEM   | INFO     | ML-KEM keypair loaded from disk | alg=ML-KEM-768
01:20:00 | Gateway      | INFO     | ML-KEM public key | alg=ML-KEM-768 | fingerprint=70a9:4ebf:f99d:299b:73c2:0e66:2365:ea9f
01:20:00 | GwIdpLink    | INFO     | ML-KEM public key registered with the IDP over mTLS | gateway_id=gw-1 | fingerprint=70a9:4ebf:f99d:299b:73c2:0e66:2365:
ea9f
01:20:00 | Gateway      | INFO     | IDP JWKS fetched over mTLS | keys=2 | kids=['d81526abaffdd837', 'c762bac6a93b609a']
01:20:00 | Firewall     | INFO     | [DRY-RUN] iptables unavailable or not running as root/NET_ADMIN - would ensure chain | chain=SDP_SPA
01:20:00 | Gateway      | INFO     | Controller: allow-all stand-in (no policy engine)
01:20:00 | Gateway      | INFO     | SPA listener starting | port=62201
01:20:00 | SPA          | INFO     | SPA listener bound | host=0.0.0.0 | port=62201
01:22:27 | SPA          | INFO     | SPA knock received | client_ip=172.24.0.1 | bytes=2423
01:22:27 | SPA          | INFO     | SPA knock verified - forwarding to Controller | client_ip=172.24.0.1 | user=alice | device=61da020b-e39c-5a06-b1da-dbd7
38978538 | port=443
01:22:27 | Controller   | INFO     | APPROVED (allow-all) | session=d9630717-124c-441f-a023-ef72c2d0b2e3 | client_ip=172.24.0.1 | user=alice | device=61da02
0b-e39c-5a06-b1da-dbd738978538 | port=443 | ttl=30
01:22:27 | Firewall     | INFO     | [DRY-RUN] would ALLOW | src_ip=172.24.0.1 | port=443 | protocol=tcp
01:22:27 | Segmentation | INFO     | Temporary access granted | client_ip=172.24.0.1 | port=443 | ttl=30
01:22:27 | SPA          | INFO     | SPA knock accepted | client_ip=172.24.0.1 | session=d9630717-124c-441f-a023-ef72c2d0b2e3
01:22:57 | Firewall     | INFO     | [DRY-RUN] would REVOKE | src_ip=172.24.0.1 | port=443 | protocol=tcp
01:22:57 | Segmentation | INFO     | Temporary access expired | client_ip=172.24.0.1 | port=443
01:40:44 | SPA          | INFO     | SPA knock verified - forwarding to Controller | client_ip=172.24.0.1 | user=alice | device=61da020b-e39c-5a06-b1da-dbd7
38978538 | port=443
01:40:44 | Controller   | INFO     | APPROVED (allow-all) | session=b29434f3-4868-476a-9fac-abd705853b86 | client_ip=172.24.0.1 | user=alice | device=61da02
0b-e39c-5a06-b1da-dbd738978538 | port=443 | ttl=30
01:40:44 | Firewall     | INFO     | [DRY-RUN] would ALLOW | src_ip=172.24.0.1 | port=443 | protocol=tcp
01:40:44 | Segmentation | INFO     | Temporary access granted | client_ip=172.24.0.1 | port=443 | ttl=30
01:40:44 | SPA          | INFO     | SPA knock accepted | client_ip=172.24.0.1 | session=b29434f3-4868-476a-9fac-abd705853b86
01:41:14 | Firewall     | INFO     | [DRY-RUN] would REVOKE | src_ip=172.24.0.1 | port=443 | protocol=tcp
01:41:14 | Segmentation | INFO     | Temporary access expired | client_ip=172.24.0.1 | port=443
```

Performance

Table A: cost of being quantum-safe

	ML-KEM-768 (ours)	X25519 (classical)
Public key	1184 B	32 B
Ciphertext	1088 B	32 B
Encapsulate	2.79 ms	0.026 ms
Decapsulate	3.65 ms	0.026 ms



Description: Quantum safety adds about 1 KB and about 3 ms per knock, which is negligible next to user input. The ML-KEM figures come from pure Python, so a **C library would be faster still.**

Table B: login time

Stage	Time
User input (password + PIN)	~16 s
IDP: registration request	53.9 ms
All system processing	< 1 s
Access window	30 S

Threat Knowledge Matrix

	Signature / labels known	No signature / labels
Aware of the threat	**Known knowns** Supervised LSTM classifier DoS, DDoS, PortScan Brute force (FTP/SSH) Bot, web attacks Feeds P(known attack)	**Known unknowns** Open-set + LSTM autoencoder New DDoS / Mirai variants Slow, stealthy scans Held-out rare attacks Feeds unknown score
Unaware of the threat	**Unknown knowns** Threat intel, CVE, MUD, UEBA Insiders, stolen logins DNS / DoH exfiltration Default creds, old CVEs Feeds policy score	**Unknown unknowns** Anomaly, drift, containment Zero-day exploits Nation-state APTs Supply-chain attacks Feeds anomaly score

Caught by trained models

Needs knowledge or containment

CHALLENGES

- **Resource Constraint Overheads:** Implementing heavy cryptographic operations like FIDO handshakes and TPM signatures on low-power IoT endpoints can introduce significant latency and power consumption.
- **Distributed Consensus Synchronization:** Maintaining reliable state synchronization and real-time Shamir's Secret Sharing reassembly across the multi-controller mesh during unpredictable edge network partitions.
- **Legacy System Interoperability:** Retrofitting heterogenous, existing IoT deployments that lack built-in TPM chips or Trusted Execution Environments (TEEs) into a strict hardware-rooted model.

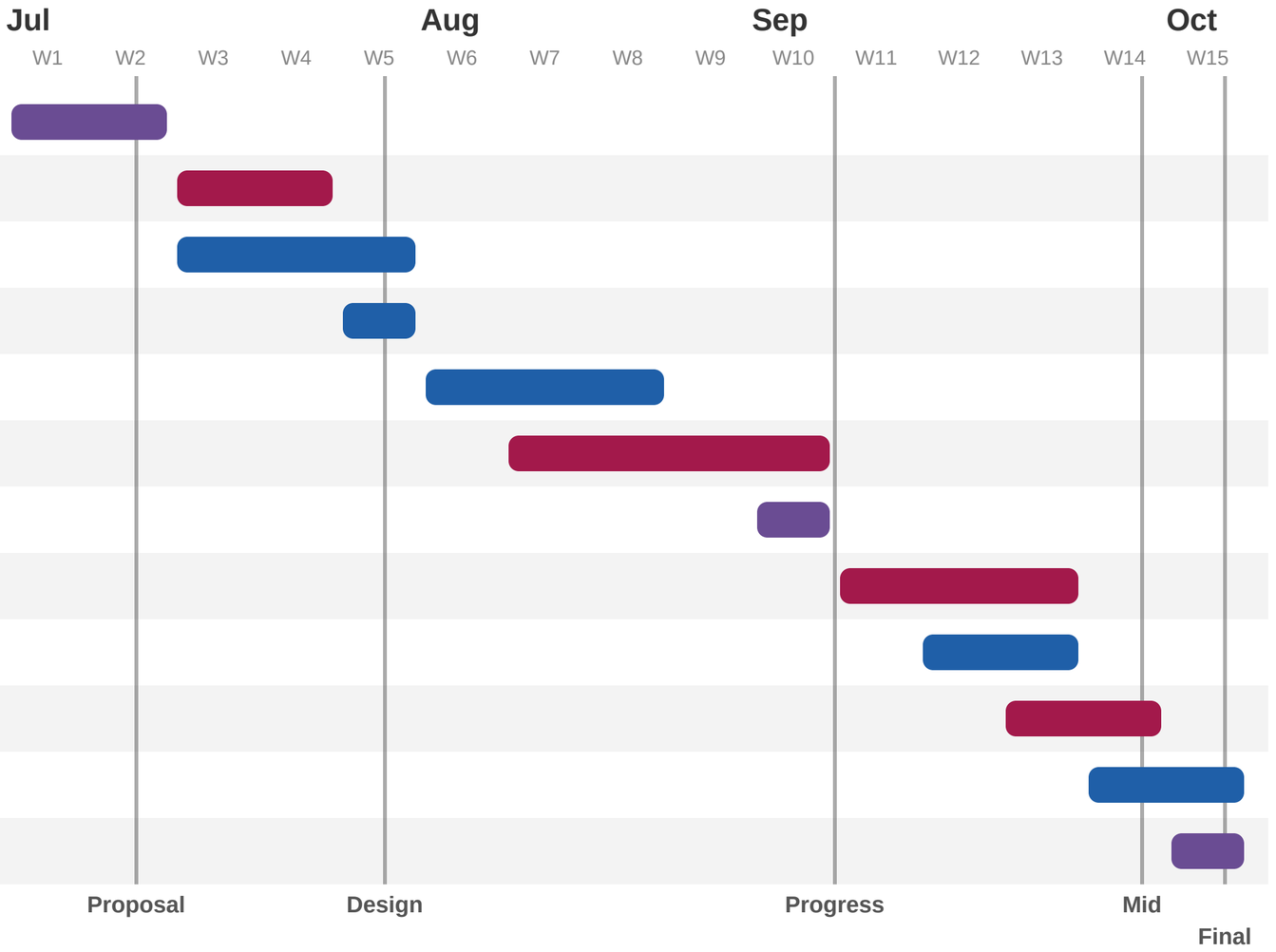
ROADMAP

Task	Status	Deadline	Notes
Proposal + Literature Survey	✅ Completed	10 Jul 2026	Analyze current ZTA frameworks (e.g., NIST 800-207), identify gaps in pre-quantum cryptography, and review literature on Shamir's Secret Sharing and post-quantum algorithms.
Design and Solution	✅ Completed	31 Jul 2026	Architecture Phase: Map out the core Post-Quantum ZTA. Design the SDP flow (SDP Controller, SDP Gateway). Define the IAM structure using Identity Providers (IDP), OIDC, and FIDO2. Design the telemetry observation pipeline for zero-knowledge data collection.
Progress Review	✅ Completed	07 Sept 2026	Baseline Prototype: Implement the foundational identity layer (FIDO2 + OIDC/IDP integration). Deploy the baseline SDP Controller and Gateway. Set up the initial Policy Administration Point (PAP) and start basic telemetry data collection. Test baseline performance metrics.
Mid Review	✏️ In progress	03 Oct 2026	Core Integration: Implement the Policy Engine and Policy Decision Point (PDP) to evaluate telemetry data dynamically. Apply Micro-segmentation rules at the SDP Gateway. Integrate Shamir's Secret Key Exchange for robust, quantum-resistant key distribution.
Final Review	⏳ Not started	10 Oct 2026	Visualization & Testing: Build and connect the Security Dashboard to visualize telemetry and access logs. Conduct full system adversarial testing (simulating both classic and quantum-era attacks). Finalize all performance matrices (latency, throughput, key exchange overhead).

Project Time line

Ajay Abhinav Both

Build task	Owner
Literature survey (ZTA, PQC, Shamir SS) + gap analysis	Both
PQ-ZTA architecture + SDP flow design	Ajay
IAM design: IdP, OIDC, FIDO2	Abhinav
Telemetry pipeline design	Abhinav
FIDO2 + OIDC IdP with TPM attestation	Abhinav
SDP controller, gateway + ML-KEM SPA knock	Ajay
PAP, telemetry collection, baseline benchmarks	Ajay
Policy Engine / PDP + trust scoring	Ajay
Micro-segmentation rules at SDP gateway	Abhinav
Shamir key exchange across controllers	Ajay
Security dashboard (telemetry + access logs)	Abhinav
Adversarial testing + final metrics	Both



Grey lines = review deadlines: 10 Jul · 31 Jul · 7 Sep · 3 Oct · 10 Oct

REFERENCES

[1] N. N. Hari et al., "Standards-Compliant Zero Trust Framework-Based Software-Defined Perimeter (SDP) for Securing Residential IoT Networks," in IEEE Transactions on Consumer Electronics, vol. 72, no. 1, pp. 1312-1327, Feb. 2026, doi: 10.1109/TCE.2026.3654782.
[2] S. Harshavardini and A. Bertia, "A Software-Defined Zero Trust Framework for Secure Access Control and Microsegmentation using SDN and SDP," 2025 Fourth International Conference on Smart Technologies, Communication and Robotics (STCR), Sathyamangalam, India, 2025, pp. 1-7, doi: 10.1109/STCR62650.2025.11020089.
[3]Safwa Ameer, Lopamudra Praharaj, Ravi Sandhu, Smriti Bhatt, and Maanak Gupta. 2024. ZTA-IoT: A Novel Architecture for Zero-Trust in IoT Systems and an Ensuing Usage Control Model. ACM Trans. Priv. Secur. 27, 3, Article 22 (August 2024), 36 pages. https://doi.org/10.1145/3671147
[4]Ekwueme, Chika & Adam, Ibrahim & Dwivedi, Avinash. (2024). Lightweight Cryptography for Internet of Things: A Review. EAI Endorsed Transactions on Internet of Things. 10.4108/eetiot.5565M. Rana, Q. Mamun, and R. Islam. 2022. Lightweight cryptography in IoT networks: A survey. Future Generation Computer Systems 129 (2022), 77–89. DOI: oT) Devices: Review. 10.2991/ahis.k.210913.033

REFERENCES

[5] J. A. Donenfeld, "WireGuard: Next Generation Kernel Network Tunnel," in Proceedings of the 2017 Network and Distributed System Security Symposium (NDSS '17), San Diego, CA, USA, Feb. 2017, doi: 10.14722/ndss.2017.23160.
[6] N. Hari N., K. Jain, P. Prabu, and P. Krishnan, "Hardware-Anchored ES-SPA: A Dynamic Zero-Trust Architecture for Secure eSIM Provisioning in 6G IoT via Moving Target Defense," Future Internet, vol. 18, no. 4, p. 187, Apr. 2026, doi: 10.3390/fi18040187.
[7] F. T. Al-Salami and A. R. R. Al-Zarrad, "Infrastructure Hardening for OT Networks: From Traditional Segmentation to Future-Proof Trusted Architectures," International Journal of Engineering Research & Technology (IJERT), vol. 12, no. 8, pp. 102-110, 2023.
[8]Y. Liu, C. Li, W. Chen, Y. Liu, and Y. Fang, "A Blockchain-Based Decentralized, Fair and Authenticated Information Sharing Scheme in Zero Trust Internet-of-Things," IEEE Transactions on Computational Social Systems, vol. 10, no. 5, pp. 2485-2497, 2023, doi: 10.1109/TCSS.2023.3268392.